



Title:- 2FA Simple bypass .

Prepared By :- Ahmed Dahman Saleh .

Date :- June.2026 .

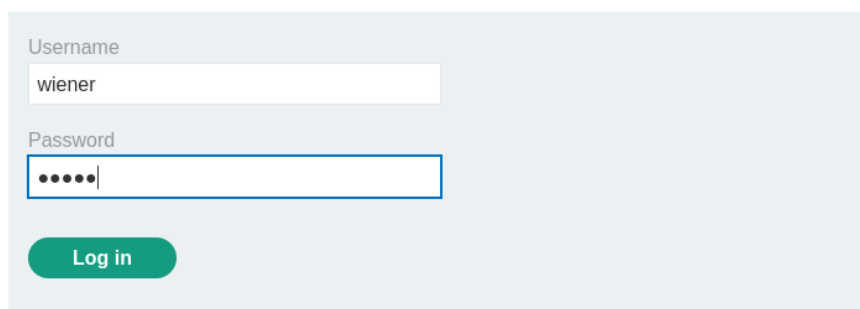
Introduction:-

This report provides a detailed analysis of a critical logic vulnerability identified within the web application's authentication flow, specifically concerning the Two-Factor Authentication (2FA) mechanism. While 2FA is intended to provide an additional layer of security beyond standard credentials, this laboratory exercise demonstrates a "2FA simple bypass" scenario.

The objective of this assessment is to explore how improper session management and insecure state validation can allow an attacker to circumvent the secondary authentication layer. By analyzing the request/response cycle and manipulating application state parameters, we identify how an attacker can gain unauthorized access to protected user sessions, thereby highlighting the risks associated with design flaws that fail to enforce consistent security controls across all application states.

Initial Authentication Attempt:-

Login



Username
wiener

Password
.....

Log in

Initiating the login process with valid user credentials (wiener) to trigger the secondary authentication requirement.

Secondary Authentication Prompt:-



2FA simple bypass

[Back to lab home](#)

[Email client](#)

[Back to lab description >>](#)

Please enter your 4-digit security code

Login

The application redirects the user to a 4-digit security code verification page, confirming the 2FA requirement is active for the current session.

Security Code Retrieval:-

Your email address is `wiener@exploit-0ac2009103b1332f806e481f0121009d.exploit-server.net`

Displaying all emails @exploit-0ac2009103b1332f806e481f0121009d.exploit-server.net and all subdomains

Sent	To	From	Subject	Body
				Hello!
				Your security code is 1875.
2026-06-13 14:56:58 +0000	wiener@exploit-0ac2009103b1332f806e481f0121009d.exploit-server.net	no-reply@0aaf00f5032733c8807a49c500a300a1.web-security-academy.net	Security code	Please enter this in the app to continue. View raw
				Thanks, Support team

Intercepting the 2FA security code via the integrated email client, which is provided to the user as a fallback mechanism for identity verification.

Targeted User Impersonation:-

Login

Username

carlos

Password

••••••

Log in

After bypassing the primary session logic, attempting to authenticate as the target user ('carlos') to evaluate if the application enforces proper session binding after the 2FA bypass.

Successful Laboratory Completion:-

← → ↻ 🏠

🔒 0aaf00f5032733c8807a49c500a300a1.web-security-academy.net/my-account

☆

👤 📁 🍌 ☰

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

WebSecurity Academy 

2FA simple bypass

LAB Solved 

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills!   Continue learning >>

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email

Successfully achieving unauthorized access to the target account ('carlos') by exploiting the logic flaw, resulting in a solved lab status.

-Broken brute-force protection,IP block :-

Introduction :-

This report documents the security assessment of the web application's authentication mechanism, specifically focusing on the robustness of its brute-force protection controls. While the application implements an IP-based blocking policy to mitigate unauthorized credential-stuffing and brute-force attacks, this laboratory exercise identifies a critical logic flaw in how these restrictions are enforced.

The objective of this assessment is to demonstrate that relying solely on IP-based tracking for rate-limiting is insufficient. By manipulating HTTP headers, such as X-Forwarded-For, an attacker can simulate requests from multiple distinct sources, effectively circumventing the IP-based protection mechanism. This vulnerability exposes user accounts to automated attacks, highlighting the necessity of implementing multi-layered security controls, such as session-based rate limiting, account lockout policies, and CAPTCHA integration, to ensure comprehensive protection against credential-based threats.

Target Identification:-

[Home](#) | [My account](#)

Login

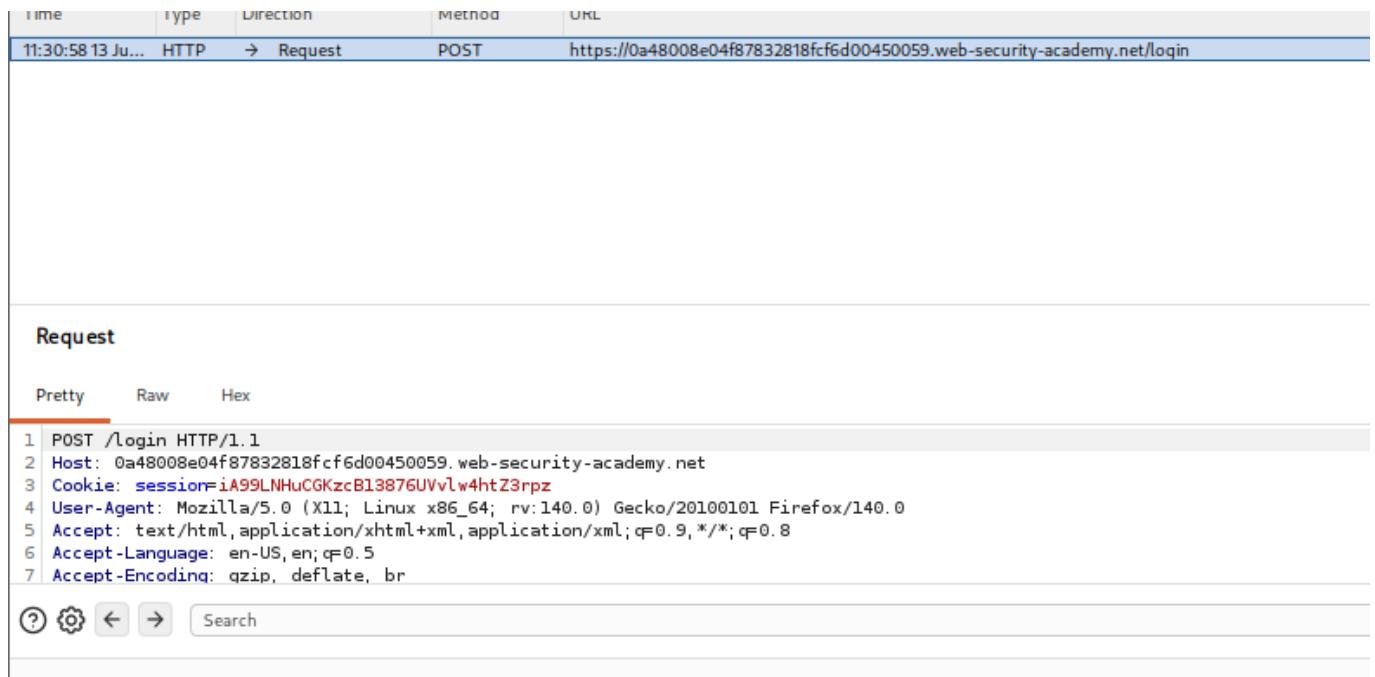
Username

Password

Log in

Navigating to the application's authentication portal to identify the target login fields and analyze the initial request structure.

Request Interception:-



The screenshot displays the Burp Suite interface with a captured HTTP request. The top bar shows the time as 11:30:58, the type as HTTP, the direction as Request, the method as POST, and the URL as https://0a48008e04f87832818fc6d00450059.web-security-academy.net/login. Below this, the 'Request' tab is active, showing the raw request details. The request is a POST to /login HTTP/1.1. The host is 0a48008e04f87832818fc6d00450059.web-security-academy.net. The cookie is session=iA99LNHuCGKzcB13876UVvIw4htZ3rpz. The user-agent is Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0. The accept headers are text/html, application/xhtml+xml, application/xml; q=0.9, */*; q=0.8. The accept-language is en-US, en; q=0.5. The accept-encoding is gzip, deflate, br. The bottom of the screenshot shows a search bar and navigation icons.

Time	Type	Direction	Method	URL
11:30:58 13 Ju...	HTTP	→ Request	POST	https://0a48008e04f87832818fc6d00450059.web-security-academy.net/login

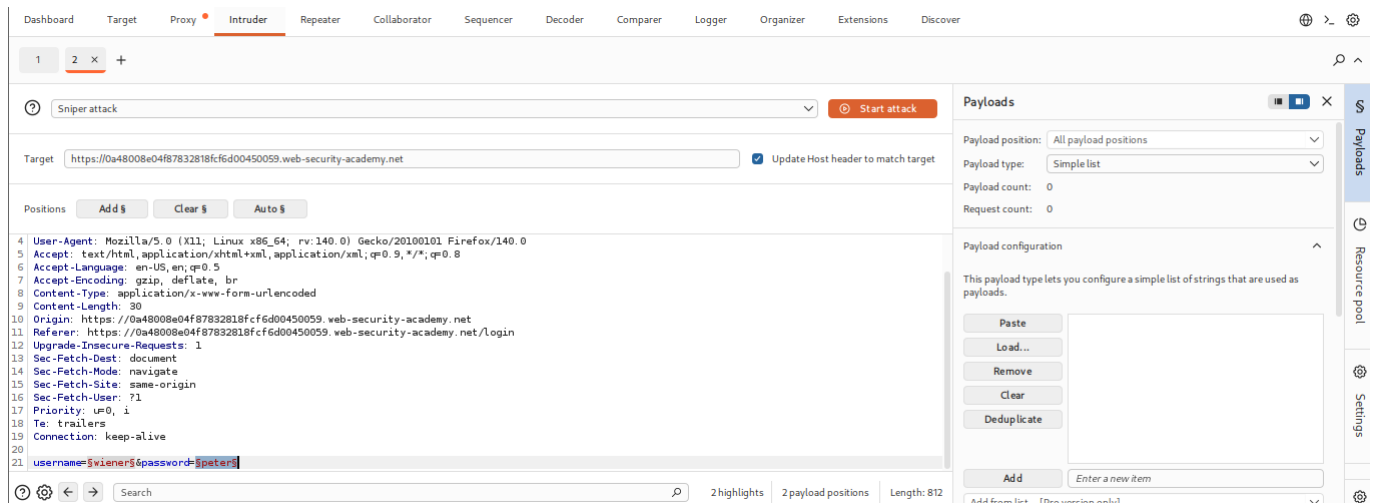
Request

Pretty Raw Hex

```
1 POST /login HTTP/1.1
2 Host: 0a48008e04f87832818fc6d00450059.web-security-academy.net
3 Cookie: session=iA99LNHuCGKzcB13876UVvIw4htZ3rpz
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: text/html, application/xhtml+xml, application/xml; q=0.9, */*; q=0.8
6 Accept-Language: en-US, en; q=0.5
7 Accept-Encoding: gzip, deflate, br
```

Capturing the POST request to the /login endpoint using Burp Suite to analyze the authentication parameters and session cookies.

Configuring Intruder Positions:-



The screenshot shows the Burp Suite Intruder tool interface. The 'Intruder' tab is active, and the 'Sniper attack' is selected. The target is https://0a48008e04f87832818fc6d00450059.web-security-academy.net. The 'Update Host header to match target' checkbox is checked. The 'Positions' section shows the request details with the username and password fields highlighted. The 'Payloads' section on the right shows the configuration for the attack, including the payload position, type, count, and request count. The 'Payload configuration' section allows for adding, loading, removing, clearing, and deduplicating payloads. The bottom of the screenshot shows a search bar and navigation icons.

Dashboard Target Proxy **Intruder** Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 2 x +

Sniper attack Start attack

Target: https://0a48008e04f87832818fc6d00450059.web-security-academy.net Update Host header to match target

Positions Add \$ Clear \$ Auto \$

```
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: text/html, application/xhtml+xml, application/xml; q=0.9, */*; q=0.8
6 Accept-Language: en-US, en; q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 30
10 Origin: https://0a48008e04f87832818fc6d00450059.web-security-academy.net
11 Referer: https://0a48008e04f87832818fc6d00450059.web-security-academy.net/login
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19 Connection: keep-alive
20
21 username=$wiener$&password=$peter$
```

2 highlights 2 payload positions Length: 812

Search

Payloads

Payload position: All payload positions

Payload type: Simple list

Payload count: 0

Request count: 0

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

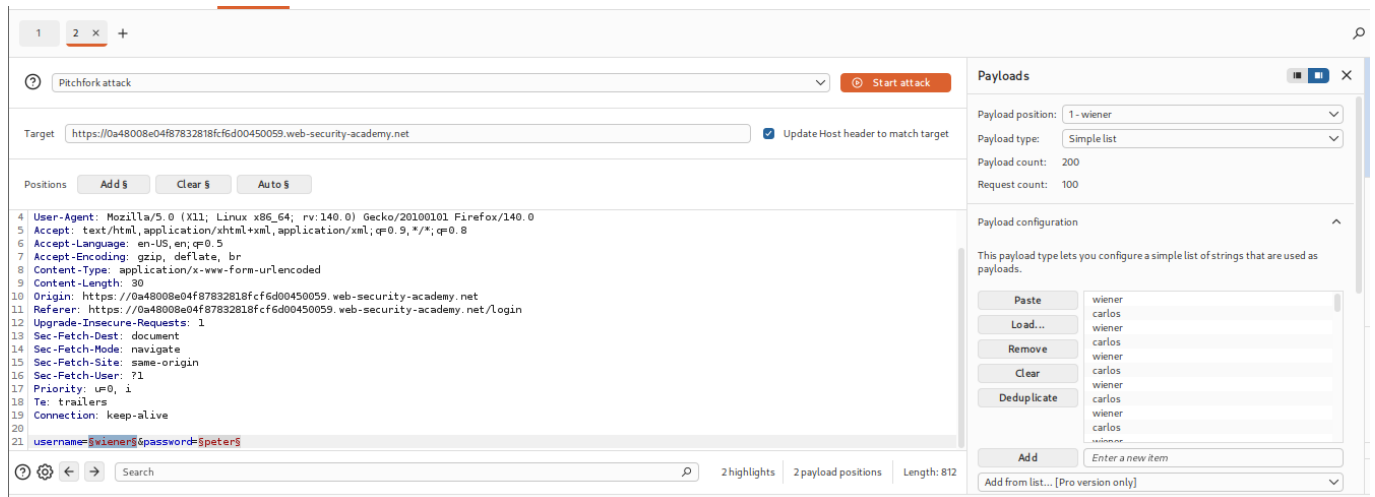
Paste Load... Remove Clear Deduplicate

Add Enter a new item

Add from list... [Pro version only]

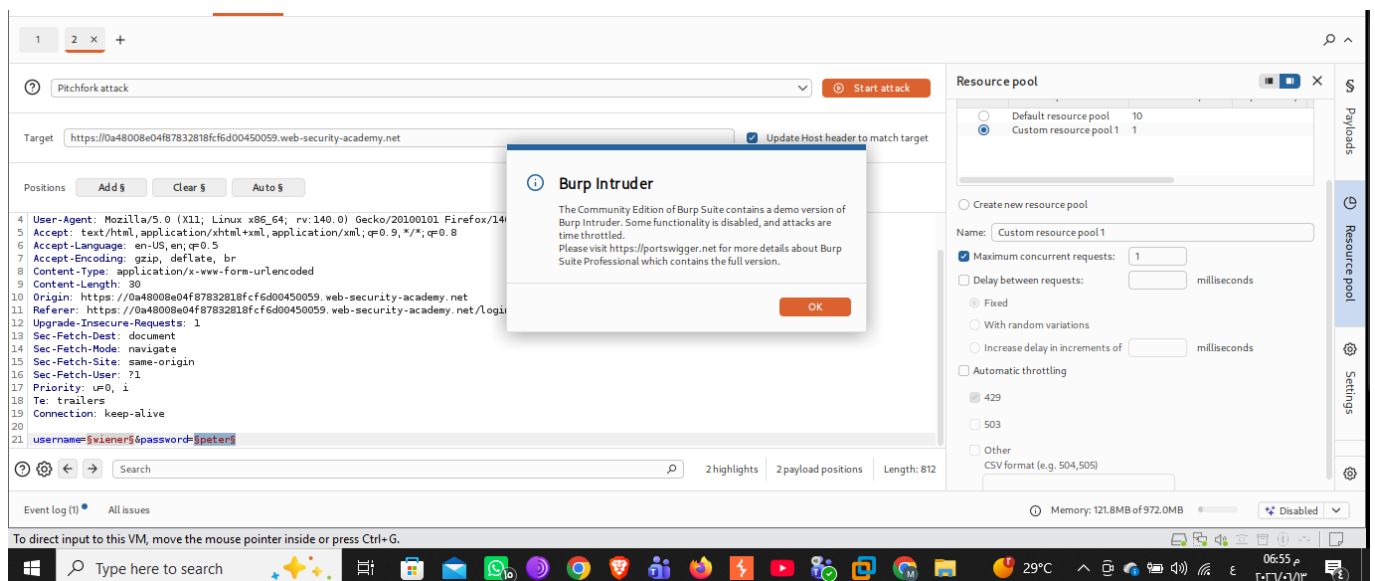
Setting the attack positions in Burp Intruder, specifically targeting the username and password fields to prepare for a credential-guessing attack.

Pitchfork Attack Configuration:-



Configuring a 'Pitchfork' attack in Burp Intruder to simultaneously iterate through lists of usernames and passwords, facilitating the brute-force process against the identified authentication mechanism.

Limitations of Testing Environment:-



Acknowledgment of using the Burp Suite Community Edition. The tool's 'time-throttled' restriction on Intruder requests necessitated manual pacing to effectively execute the brute-force attack while remaining within the software's functional constraints.

